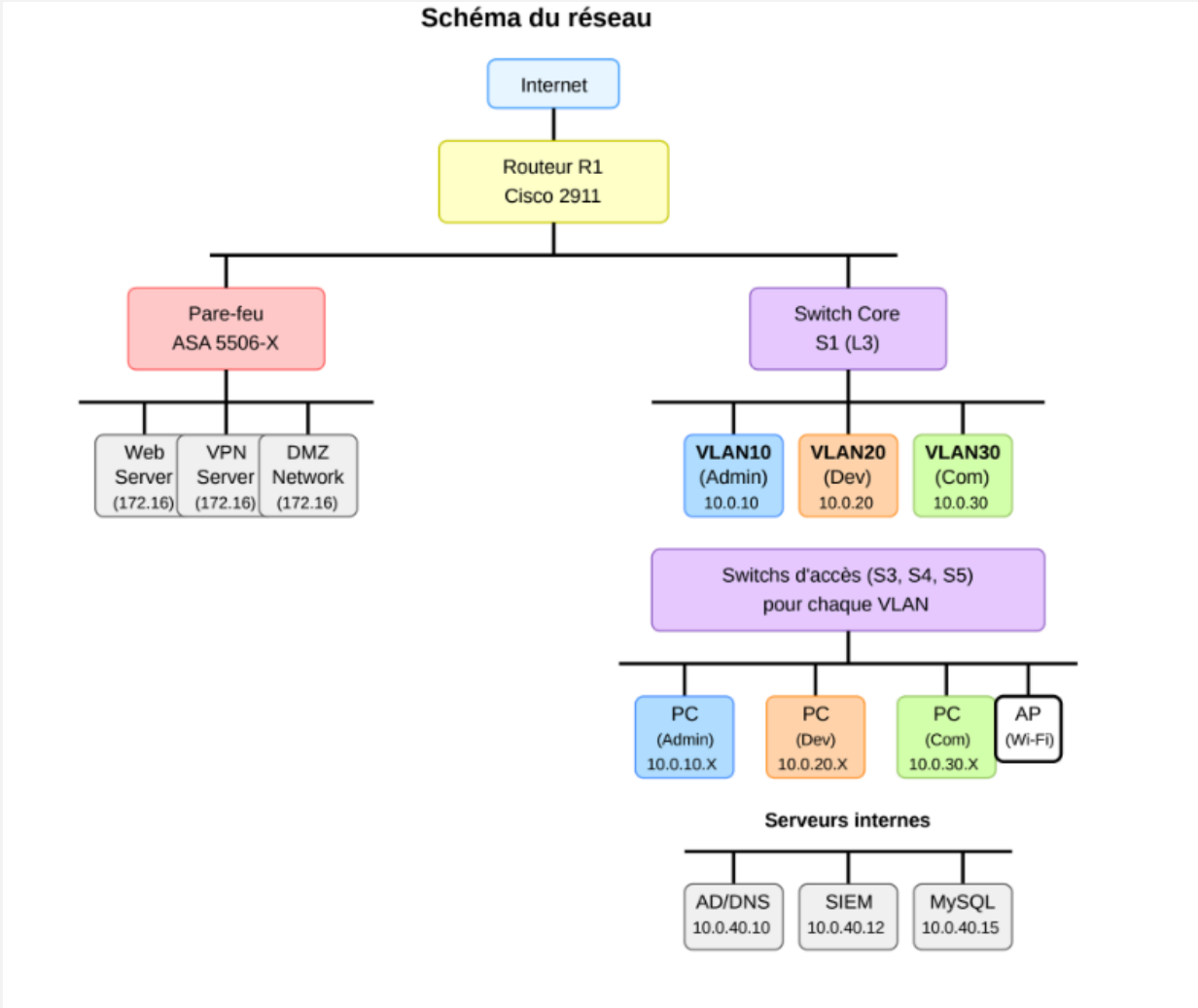


Gestion des risques - TechSecure



Étape 1 : Identification des actifs critiques

L'objectif de cette étape est de déterminer **les éléments essentiels au fonctionnement de TechSecure**, afin de concentrer les efforts de sécurité sur ce qui a le plus de valeur.

1. Actifs les plus sensibles

Les actifs critiques identifiés sont les suivants :

- **Données clients**
 - Informations sensibles confiées par les clients
 - Risque majeur en cas de fuite (RGPD, réputation, pertes financières)
- **Code source**
 - Cœur de l'activité de TechSecure
 - Risque de vol, sabotage ou copie par un concurrent
- **Serveurs internes (VLAN 40)**
 - **Active Directory / DNS** : gestion des accès et du réseau
 - **MySQL/MariaDB** : stockage des données critiques
 - **SIEM** : supervision et détection des incidents
- **Serveurs exposés en DMZ**
 - **Serveur Web** : accessible depuis Internet
 - **Serveur VPN** : point d'entrée distant vers le réseau interne
- **Équipements réseau**
 - **Pare-feu** : contrôle des flux réseau
 - **Routeur** : accès Internet
 - **Switch cœur (L3)** : distribution du trafic interne
- **Postes utilisateurs**
 - Points d'entrée privilégiés pour les attaques (phishing, malware)
- **Réseau Wi-Fi**
 - Accès potentiellement moins sécurisé au réseau interne
- **Réseau de management (VLAN 99)**
 - Permet l'administration des équipements
 - Très sensible en cas d'accès non autorisé

2. Synthèse de la criticité

Les actifs les plus critiques pour l'entreprise sont :

- Données clients
- Code source
- Active Directory / DNS
- Base de données
- Serveur VPN

Ces éléments représentent **les cibles prioritaires pour un attaquant** et doivent donc être **protégés en priorité**.

3. Conclusion pédagogique

Cette étape permet de répondre à une question clé :

“Qu’est-ce que l’entreprise ne peut absolument pas se permettre de perdre ou de compromettre ?”

Chez TechSecure, la réponse est claire :

les données, les accès au système, et les composants centraux de l’infrastructure.

Étape 2 — Identification des menaces

L’analyse des menaces consiste à recenser les scénarios d’attaque plausibles visant l’infrastructure de TechSecure.

L’entreprise héberge des services exposés en DMZ, notamment un serveur Web et un serveur VPN, ainsi que des serveurs internes critiques comme l’AD/DNS, le SIEM et la base MySQL. Elle traite également des données sensibles telles que les informations clients et le code source des logiciels de sécurité.

Les menaces peuvent être classées en quatre catégories :

Attaquants externes opportunistes : ils exploitent les faiblesses les plus visibles, comme les campagnes de phishing, les rançongiciels, les scans de services exposés ou les attaques DDoS contre les services publics.

Attaquants externes sophistiqués : ils cherchent un accès durable et discret afin de voler des données clients, du code source ou de compromettre les serveurs critiques. Le serveur VPN et la DMZ constituent ici des cibles de choix.

Menaces internes malveillantes : un collaborateur ou prestataire disposant déjà d’un accès peut voler des informations, abuser de privilèges ou saboter le fonctionnement du SI.

Menaces internes non intentionnelles : une erreur humaine, comme l’ouverture d’un e-mail piégé ou une mauvaise configuration, peut aussi provoquer un incident de sécurité majeur.

Un point d’attention particulier concerne la base MySQL, car le compte `dev_user` autorisé depuis le VLAN Développement dispose de privilèges très élevés sur la base. En cas de compromission d’un poste développeur, cette configuration pourrait faciliter une attaque sur les données internes.

Conclusion

À ce stade, on peut retenir que les menaces les plus réalistes pour TechSecure sont :

- le **phishing**,
- le **ransomware**,
- l'**attaque DDoS** sur les services exposés,
- le **vol de données internes**,
- l'**intrusion ciblée via la DMZ ou le VPN**,
- l'**abus de privilèges** depuis l'interne ou depuis un poste développeur compromis.

Étape 3 — Évaluation des contrôles de sécurité (TechSecure)

Cette étape consiste à analyser les **mécanismes de sécurité existants** et à identifier ceux qui sont **absents, mal configurés ou insuffisants** dans l'infrastructure décrite .

1. Analyse des contrôles existants

1.1 Pare-feu (ASA 5506-X)

- Présence d'un pare-feu avec segmentation logique :
 - **inside** (niveau 100)
 - **dmz** (niveau 50)
 - **outside** (niveau 0)

Point positif :

- Bonne base de segmentation entre réseau interne, DMZ et Internet.

Limite observée :

- Aucune règle ACL explicite visible → comportement potentiellement **trop permissif par défaut**.

Segmentation réseau (VLAN)

- VLANs définis :
 - Admin (10)
 - Dev (20)
 - Commercial (30)
 - Serveurs (40)
 - Management (99)

Point positif :

- Bonne séparation logique des métiers.

Limites :

- Aucune politique de filtrage inter-VLAN mentionnée
- Risque de communication libre entre VLANs

1.2 Wi-Fi (AP1 / AP2)

- WPA2-PSK configuré avec mot de passe partagé

Point positif :

- Chiffrement AES activé

Limites critiques :

- Mot de passe **statique et partagé** → difficile à contrôler
- Aucun mécanisme d'authentification forte (type WPA2-Enterprise)

1.3 Base de données (MySQL)

- Utilisateur `dev_user` avec :
 - Accès depuis tout le VLAN Dev (`10.0.20.%`)
 - **Tous les privilèges + GRANT OPTION**

Problèmes majeurs :

- Principe du moindre privilège non respecté
- Risque de compromission totale de la base

1.4 NAT et accès Internet

- NAT configuré sur le routeur

Point positif :

- Masquage des adresses internes

Limite :

- Aucun filtrage sortant mentionné (exfiltration possible)

2. Identification des contrôles manquants ou mal configurés

2.1 Pare-feu

- Absence de règles ACL restrictives
- Pas de filtrage fin entre DMZ et LAN
- Pas de politique de filtrage sortant

2.2 Segmentation réseau

- Pas de contrôle des flux inter-VLAN
- VLAN Management potentiellement accessible
- Pas de micro-segmentation (ex : isolation serveurs critiques)

2.3 Wi-Fi

- Pas de WPA2-Enterprise (authentification individuelle)
- Pas de segmentation Wi-Fi (invités vs interne)
- Mot de passe exposé à long terme

2.4 Gestion des accès

- Droits excessifs sur la base de données
- Pas de gestion des rôles (RBAC)
- Pas de journalisation des accès D

2.5 Supervision et détection

- Aucune mention de :
 - IDS/IPS
 - Monitoring réseau
 - Alertes de sécurité

2.6 Gestion des accès réseau

- Pas d'authentification forte (MFA)
- Pas de contrôle d'accès réseau (NAC)
- Pas de gestion centralisée des identités (IAM visible)

3. Synthèse des faiblesses critiques

Domaine	Problème	Risque associé
Pare-feu	Règles trop permissives	Intrusion réseau
VLAN	Pas de filtrage inter-VLAN	Mouvement latéral
Wi-Fi	Mot de passe partagé	Accès non autorisé
Base de données	Droits excessifs	Fuite ou destruction de données
Supervision	Absente	Attaques non détectées
Accès	Pas de MFA	Compromission des comptes

4. Conclusion

Un bon contrôle de sécurité repose sur 3 principes fondamentaux :

1. **Limitier les accès (moindre privilège)**
2. **Segmenter intelligemment les réseaux**
3. **Surveiller en continu les activités**

Dans le cas de TechSecure, l'infrastructure est **correctement structurée**, mais **insuffisamment sécurisée dans ses règles et contrôles opérationnels**.

Étape 4 —Plan de remédiation (TechSecure)

Cette étape consiste à **corriger les vulnérabilités identifiées** en priorisant les actions selon leur criticité (impact × probabilité). L'objectif est d'optimiser l'effort tout en réduisant rapidement le niveau de risque global.

1. Logique de priorisation

Le plan de remédiation repose sur 3 niveaux :

Priorité	Objectif	Délai
Court terme	Corriger les risques critiques exploitables immédiatement	0–30 jours
Moyen terme	Renforcer la sécurité structurelle	1–3 mois
Long terme	Améliorer la résilience et la maturité globale	3–12 mois

2. Actions prioritaires (Court terme)

2.1 Sécurisation des accès critiques

- Changer tous les mots de passe exposés dans les configurations (ex : routeur, Wi-Fi, base de données)
- Mettre en place une politique de mots de passe robustes
- Désactiver les accès inutiles ou par défaut

Justification : Les identifiants faibles sont exploitables immédiatement par un attaquant.

2.2 Durcissement du pare-feu

- Restreindre les règles trop permissives entre :
 - VLAN utilisateurs ↔ serveurs internes
 - DMZ ↔ réseau interne
- Autoriser uniquement les flux nécessaires (principe du **moindre privilège**)

Justification : Une mauvaise configuration permet des mouvements latéraux rapides.

Sécurisation de la base de données

- Supprimer le **GRANT ALL PRIVILEGES** global
- Limiter les droits au strict nécessaire (principe **least privilege**)
- Restreindre les accès par IP précises

Justification : Une compromission d'un poste dev donne actuellement accès total aux données.

2.3 Sécurisation du Wi-Fi

- Remplacer la clé Wi-Fi partagée par une authentification forte (WPA2-Enterprise idéalement)
- Segmenter le Wi-Fi du réseau interne

Justification : Le Wi-Fi est un point d'entrée facile pour un attaquant opportuniste.

3. Actions de renforcement (Moyen terme)

3.1 Amélioration de la segmentation réseau

- Isoler strictement :
 - VLAN utilisateurs
 - VLAN serveurs
 - VLAN management
- Interdire les communications directes non nécessaires

Justification : Limite la propagation d'une attaque interne.

3.2 Mise en place d'un contrôle des accès

- Déployer une authentification centralisée (Active Directory + MFA)
- Mettre en place des rôles utilisateurs (RBAC)

Justification : Réduction du risque d'abus de privilèges.

3.3 Déploiement de solutions de sécurité

- Antivirus / EDR sur tous les postes
- IDS/IPS sur le réseau
- Renforcement du SIEM existant (logs + corrélation)

Justification : Améliore la détection des attaques.

3.4 Gestion des mises à jour

- Mettre en place un processus de patch management
- Maintenir à jour :
 - OS
 - équipements réseau
 - applications

Justification : Les vulnérabilités connues sont les plus exploitées.

4. Actions stratégiques (Long terme)

4.1 Mise en place d'un plan de gestion des risques continu

- Revue régulière des risques
- Audit de sécurité périodique
- Tests d'intrusion (pentest)

4.2 Sensibilisation des employés

- Formation contre le phishing
- Bonnes pratiques de sécurité
- Simulations d'attaques

Justification : L'humain reste la première faille.

4.3 Amélioration de l'architecture

- Mise en place de redondance (serveurs, réseau)
- Sécurisation avancée de la DMZ
- Architecture Zero Trust (à terme)

5. Synthèse opérationnelle

Action	Priorité	Impact sécurité
Changement des mots de passe		Très élevé
Correction des règles firewall		Très élevé
Restriction accès base de données		Très élevé
Segmentation réseau		Élevé
Déploiement EDR / SIEM		Élevé
Sensibilisation utilisateurs		Moyen mais durable

Conclusion pédagogique

Le plan de remédiation de TechSecure suit une logique simple :

Bloquer rapidement les attaques faciles → renforcer l'infrastructure → améliorer la maturité globale

Cela permet :

- une **réduction immédiate du risque**
- une **sécurisation progressive**
- une **optimisation des ressources de la PME**

Étape 5 — Étude d'impact business (BIA)

Cette étape vise à **traduire les risques techniques en conséquences métier concrètes**. On ne parle plus uniquement de serveurs ou de VLANs, mais de **perte financière, interruption d'activité et atteinte à la réputation**.

1. Identification des actifs critiques

À partir du contexte de , les actifs clés de **TechSecure** sont :

Données clients

- Informations sensibles confiées par les clients
- Potentiellement soumises au RGPD

Pourquoi critique ?

→ Cœur de la confiance client et de l'activité commerciale

Code source des solutions de cybersécurité

- Propriété intellectuelle stratégique

Pourquoi critique ?

→ Avantage concurrentiel direct de l'entreprise

Serveurs internes (AD, SIEM, MySQL)

- Authentification (AD/DNS)
- Stockage des données (MySQL)
- Supervision sécurité (SIEM)

Pourquoi critique ?

→ Pilier du fonctionnement interne et de la sécurité globale

Infrastructure réseau (routeur, firewall, VLAN, DMZ)

- Assure la connectivité et la segmentation

Pourquoi critique ?

→ Une faille ici impacte toute l'entreprise

Site web et services exposés (DMZ)

- Web server + VPN server

Pourquoi critique ?

→ Point d'entrée externe → forte surface d'attaque

2. Analyse des impacts en cas de compromission

Tableau de synthèse

Actif compromis	Impact financier	Impact opérationnel	Impact réputation	Impact légal
Données clients	Très élevé	Élevé	Très élevé	Très élevé (RGPD)
Code source	Très élevé	Moyen	Élevé	Moyen
Serveurs internes	Élevé	Très élevé	Moyen	Faible
Infrastructure réseau	Élevé	Très élevé	Élevé	Faible
Site web / DMZ	Moyen	Élevé	Élevé	Faible

3. Scénarios d'impact concrets

Cas 1 : Fuite de données clients

- Sanctions RGPD (amendes)
- Perte de clients
- Crise de confiance

Impact global : **critique (business en danger)**

Cas 2 : Attaque ransomware sur serveurs internes

- Blocage des opérations
- Perte d'accès aux données
- Coût de remédiation élevé

Impact global : **très élevé (arrêt d'activité)**

Cas 3 : Compromission du site web (DMZ)

- Défiguration ou indisponibilité
- Porte d'entrée vers le réseau interne

Impact global : **élevé (image + sécurité)**

Cas 4 : Vol du code source

- Revente ou fuite publique
- Perte d'avantage concurrentiel

Impact global : **très stratégique**

4. Priorisation des actifs (vision métier)

Criticité maximale

- Données clients
- Serveurs internes (AD, MySQL)

Criticité élevée

- Infrastructure réseau
- Site web / DMZ

Criticité stratégique

- Code source

5. Conclusion

- Les **données clients** représentent le risque business majeur (financier + légal)
- Les **serveurs internes** sont critiques pour la continuité d'activité
- L'**infrastructure réseau** est un point de défaillance global
- La **DMZ** est une zone à haut risque (exposition Internet)
- Le **code source** est un actif stratégique à forte valeur

L'étude d'impact montre que :

- Une compromission peut entraîner **arrêt complet de l'activité**
- Les risques ne sont pas seulement techniques mais **directement business**
- Les priorités de sécurité doivent se concentrer sur :
 - Protection des données
 - Disponibilité des systèmes
 - Contrôle des accès réseau

Étape 6 — Analyse de conformité (RGPD & bonnes pratiques)

Cette étape consiste à vérifier si l'infrastructure et les configurations de **TechSecure** respectent les exigences réglementaires, en particulier le RGPD, ainsi que les bonnes pratiques en cybersécurité.

1. Rappel du contexte réglementaire

Le RGPD impose plusieurs obligations clés aux entreprises traitant des données personnelles :

- **Confidentialité** : empêcher l'accès non autorisé aux données
- **Intégrité** : garantir que les données ne sont pas altérées
- **Disponibilité** : assurer l'accès aux données en cas de besoin
- **Traçabilité** : journaliser les accès et actions
- **Minimisation** : limiter les accès aux données nécessaires

Dans le cas de TechSecure :

- Données clients sensibles stockées (bases MySQL, SIEM, etc.)
- Infrastructure exposée (DMZ, accès internet, Wi-Fi)

Le niveau d'exigence est donc **élevé**.

2. Analyse de conformité technique

2.1 Gestion des accès (**NON conforme**)

Constat :

- Utilisateur MySQL avec privilèges **FULL + GRANT OPTION** :

```
GRANT ALL PRIVILEGES ON *.* TO 'dev_user'
```

- Accès autorisé depuis tout le VLAN Dev (**10.0.20.%**)

Problème :

- Non-respect du principe de **moindre privilège (least privilege)**
- Risque élevé d'abus ou de compromission

Conclusion :

Non conforme RGPD (accès trop large aux données)

2.2 Sécurisation des authentifications (**PARTIEL**)

Constat :

- Wi-Fi protégé par WPA2-PSK avec mot de passe statique
- Mot de passe visible en configuration (**TechSecure@2025!**)

Problème :

- Pas de gestion centralisée des identités (pas de WPA2-Enterprise)
- Difficulté à tracer les utilisateurs

Conclusion :

Partiellement conforme (authentification insuffisamment robuste)

2.3 Journalisation et traçabilité (**NON conforme**)

Constat :

- Aucune configuration explicite de logs (firewall, routeur, base de données)
- SIEM présent mais non exploité clairement

Problème :

- Impossible de détecter ou prouver une violation de données

Conclusion :

Non conforme RGPD (obligation de traçabilité non respectée)

2.4 Cloisonnement réseau (PARTIEL)**Constat :**

- VLANs séparés (Admin, Dev, Commercial, Serveurs)
- Présence d'une DMZ

Mais :

- Pas de règles firewall détaillées (filtrage inter-VLAN inconnu)
- Routage possible sans restriction

Problème :

- Risque de déplacement latéral (attaque interne)

Conclusion :

Partiellement conforme (segmentation insuffisamment sécurisée)

2.5 Protection des données (NON conforme)**Constat :**

- Aucun chiffrement mentionné pour :
 - Base de données
 - Communications internes

Problème :

- Données sensibles potentiellement exposées en clair

Conclusion :

Non conforme RGPD (absence de chiffrement)

2.6 Gestion des mots de passe (NON conforme)**Constat :**

- Mot de passe en clair dans les configurations :
 - Routeur (`enable secret`)
 - Wi-Fi
- Mot de passe simple (`DevPass123!`)

Problème :

- Non-respect des bonnes pratiques de sécurité

Conclusion :

Non conforme (risque de compromission élevé)

3. Synthèse de conformité

Domaine	Niveau de conformité
Gestion des accès	Non conforme
Authentification	Partielle
Journalisation	Non conforme
Segmentation réseau	Partielle
Protection des données	Non conforme
Gestion des mots de passe	Non conforme

Conclusion globale : NON CONFORME RGPD

4. Risques réglementaires identifiés

- Fuite de données clients sensibles
- Amende RGPD (jusqu'à 4% du CA annuel)
- Perte de confiance des clients
- Responsabilité légale en cas d'incident

5. Conclusion

Pour simplifier :

- TechSecure **protège mal ses données critiques**
- Les accès sont **trop larges**
- Les actions ne sont **pas tracées**
- Les protections (chiffrement, authentification) sont **insuffisantes**

En cas d'attaque, l'entreprise serait :

- vulnérable techniquement
- **et non conforme légalement**

Étape 7 — Élaboration d'un Plan de Continuité d'Activité (PCA)

Objectif garantir la disponibilité des services critiques de *TechSecure* même en cas d'incident majeur (cyberattaque, panne, erreur humaine), en limitant l'interruption et les pertes métiers.

1. Identification des services essentiels

À partir de l'infrastructure fournie , les services critiques sont :

Service	Rôle	Impact si indisponible
Serveur Web (DMZ)	Accès client aux services	Perte de revenus / image
Base de données (MySQL VLAN 40)	Stockage données clients	Perte de données critiques
Active Directory / DNS	Authentification interne	Blocage total du SI
VPN (DMZ)	Accès distant sécurisé	Interruption du télétravail
SIEM	Supervision sécurité	Perte de visibilité sur les attaques

Ces éléments doivent être **priorisés dans le PCA**.

2. Scénarios d'incidents à couvrir

Les menaces identifiées précédemment se traduisent en scénarios concrets :

- Ransomware sur les serveurs internes (VLAN 40)
- Attaque DDoS sur le serveur Web (DMZ)
- Perte ou corruption de la base de données
- Panne réseau (routeur R1 ou firewall FW1)
- Compromission d'un compte administrateur

3. Stratégies de continuité

3.1 Sauvegardes (Backups)

Objectif : restaurer rapidement les données

- Sauvegardes automatiques :
 - Base MySQL → quotidien
 - AD/DNS → quotidien
- Stockage :
 - Local (rapide)
 - Externalisé (cloud sécurisé)
- Règle recommandée :
 - **3-2-1** : 3 copies, 2 supports différents, 1 hors site

Sans sauvegarde fiable, aucune continuité n'est possible.

3.2 Redondance des infrastructures

Objectif : éviter les points de défaillance uniques

Constat actuel :

- Routeur R1 et Firewall FW1 = points critiques uniques

Améliorations :

- Firewall en haute disponibilité (actif/passif)
- Serveur Web en cluster ou load balancing
- Base de données avec réplication
- Lien Internet secondaire

3.3 Plan de Reprise d'Activité (PRA)

Objectif : redémarrer après incident

Définir :

- RTO (Recovery Time Objective) :
 - Web : < 2h

- DB : < 4h
 - AD : < 2h
- RPO (Recovery Point Objective) :
 - Perte max de données :
 - DB : 24h max
 - SIEM : quelques heures

Procédures :

1. Isoler le système compromis
2. Restaurer depuis sauvegarde
3. Vérifier intégrité
4. Remettre en production

3.4 Continuité réseau

Objectif : maintenir la connectivité

Actions :

- Configuration de routes de secours
- Segmentation réseau stricte (VLANs déjà présents mais à renforcer)
- Surveillance des équipements critiques (R1, FW1, S1)

3.5 Gestion de crise

Objectif : coordonner efficacement la réponse

Mettre en place :

- Cellule de crise (IT + direction)
- Procédure de communication interne/externe
- Documentation claire :
 - Qui fait quoi ?
 - Dans quel ordre ?

4. Priorisation des actions

Court terme (immédiat)

- Mettre en place sauvegardes automatiques

- Documenter procédures PRA
- Restreindre accès critiques (ex: DB)

Moyen terme

- Implémenter redondance serveur Web et DB
- Tester régulièrement les restaurations
- Déployer supervision SIEM efficace

Long terme

- Haute disponibilité complète (Firewall, réseau)
- Automatisation reprise (scripts, orchestration)
- Exercices de simulation de crise

5. Synthèse opérationnelle

Un PCA efficace pour TechSecure repose sur 4 piliers :

1. **Prévention** → sauvegardes, segmentation
2. **Résilience** → redondance
3. **Réactivité** → procédures PRA
4. **Organisation** → gestion de crise

Point critique à retenir

L'infrastructure actuelle présente des **points de défaillance uniques (R1, FW1, DB)** qui mettent en risque la continuité globale.

Sans correction, un incident unique peut entraîner **un arrêt complet de l'activité**.

6. Résultat attendu

Avec ce plan :

- Réduction drastique du temps d'arrêt
- Protection des données clients
- Maintien de la confiance client
- Conformité facilitée (RGPD à venir)

Étape 8 — Analyse de conformité — RGPD

L'infrastructure de TechSecure présente plusieurs mesures de sécurité positives, notamment la segmentation réseau, la présence d'une DMZ, d'un pare-feu dédié et d'un SIEM.

Toutefois, l'analyse montre des écarts importants vis-à-vis du RGPD : droits excessifs sur la base MySQL, secrets exposés dans les configurations, absence de preuve de limitation stricte des accès, documentation de conformité non fournie et procédure de gestion des violations non démontrée.

En conséquence, l'environnement peut être considéré comme **partiellement conforme**, avec plusieurs **non-conformités majeures** à corriger en priorité.

Le principal problème n'est pas l'absence totale de sécurité, mais le fait que les mesures visibles ne garantissent pas encore :

- la **limitation stricte des accès** ;
- la **protection des données par défaut** ;
- la **maîtrise des habilitations** ;
- la **traçabilité** ;
- la **documentation de conformité** ;
- la **gestion formalisée des violations de données**.

En synthèse, on peut écrire que **TechSecure est partiellement alignée sur les exigences techniques du RGPD, mais non conforme sur plusieurs points critiques de gouvernance, d'habilitation et de protection des données personnelles**.

Recommandations immédiates de mise en conformité:

Court terme

- retirer **GRANT ALL PRIVILEGES** et **WITH GRANT OPTION** au compte développeur ;
- créer des comptes nominatifs avec privilèges minimaux ;
- remplacer les secrets exposés par une gestion centralisée des mots de passe et secrets ;
- documenter une procédure de violation de données avec notification CNIL sous 72 h ;
- vérifier les journaux du pare-feu, des serveurs, du Wi-Fi et de MySQL.

Moyen terme

- mettre en place un Wi-Fi d'entreprise avec authentification individuelle ;
- formaliser une matrice d'habilitation par fonction ;
- documenter le registre des traitements ;
- définir les durées de conservation et les bases légales de traitement.

Long terme

- intégrer une vraie logique **privacy by design** dans les projets techniques ;
- réaliser une revue régulière de conformité sécurité/RGPD ;
- relier les alertes SIEM à un processus de gestion d'incident et de preuve.

Étape 9 — Élaboration de règles adaptées à l'infrastructure TechSecure

À partir de l'architecture fournie, TechSecure dispose d'un réseau segmenté en plusieurs VLAN métiers, d'une DMZ, d'un pare-feu ASA, d'un routeur d'accès Internet, d'un Wi-Fi d'entreprise, ainsi que de serveurs sensibles comme l'AD/DNS, le SIEM et MySQL. Le sujet demande explicitement de définir des règles adaptées à cette infrastructure, en cohérence avec les risques déjà identifiés.

1. Objectif de cette étape

L'objectif ici n'est pas seulement de "mettre des règles", mais de définir un cadre de sécurité cohérent pour :

- limiter les communications inutiles ;
- empêcher les déplacements latéraux entre VLAN ;
- protéger les serveurs critiques ;
- encadrer les accès d'administration ;
- réduire l'impact d'une compromission interne ou externe.

En pratique, une bonne règle de sécurité suit toujours la même logique :

“Autoriser seulement ce qui est nécessaire, refuser le reste par défaut.”

2. Contexte réseau à prendre en compte

L'infrastructure est organisée autour de plusieurs segments :

- **VLAN 10** : Administration
- **VLAN 20** : Développement
- **VLAN 30** : Commercial + Wi-Fi
- **VLAN 40** : Serveurs internes
- **VLAN 99** : Management
- **DMZ** : serveurs exposés, notamment Web et VPN
- **Serveurs critiques internes** : AD/DNS 10.0.40.10, SIEM 10.0.40.12, MySQL 10.0.40.15

Ce découpage est pertinent sur le papier, mais il n'est réellement sécurisé que si des règles de filtrage viennent imposer des frontières strictes entre ces zones. Le simple fait d'avoir des VLAN ne suffit pas.

3. Principes directeurs des règles à appliquer

Pour TechSecure, les règles doivent reposer sur 5 principes simples :

3.1 Segmentation stricte

Chaque VLAN doit être traité comme une zone distincte.

Un poste compromis dans le VLAN Commercial ne doit pas pouvoir explorer librement les serveurs internes ou les postes d'administration.

3.2 Moindre privilège réseau

Un flux ne doit être autorisé que s'il répond à un besoin métier ou technique clairement identifié.

3.3 Séparation des usages

L'administration, les services métiers, le Wi-Fi, la DMZ et la base de données doivent être isolés.

3.4 Traçabilité

Toute règle sensible doit être journalisée : accès refusés, connexions vers la DMZ, tentatives sur le VLAN 99, accès à la base, connexions VPN.

3.5 Administration sécurisée

Les accès de gestion doivent être réservés à des postes autorisés, depuis le VLAN Administration ou un bastion dédié.

4. Règles réseau recommandées

4.1 Règles inter-VLAN

Règle 1 — Interdire par défaut les communications entre VLAN

Principe : aucun VLAN utilisateur ne doit communiquer librement avec un autre.

Pourquoi : cela limite fortement la propagation d'un malware, d'un ransomware ou d'un compte compromis.

Application :

- VLAN 10 ↔ VLAN 20 : interdit sauf besoins précis
- VLAN 10 ↔ VLAN 30 : interdit
- VLAN 20 ↔ VLAN 30 : interdit
- VLAN 30 ↔ VLAN 40 : interdit sauf services explicitement autorisés
- VLAN 20 ↔ VLAN 40 : autorisé uniquement pour les flux de développement nécessaires
- VLAN 99 ↔ tous les autres : réservé à l'administration réseau

Règle 2 — Autoriser seulement les flux métiers nécessaires vers le VLAN 40

Le VLAN 40 contient les serveurs internes les plus sensibles. Il doit être traité comme une zone à haut niveau de protection.

Exemples d'autorisations minimales :

- VLAN 10 → AD/DNS : DNS, LDAP, LDAPS, Kerberos, RDP/SSH si nécessaire
- VLAN 20 → MySQL : uniquement port MySQL si l'application le nécessite
- VLAN 20 → dépôt Git ou serveur de build : selon besoin réel
- VLAN 30 → aucun accès direct aux serveurs internes, sauf services applicatifs explicitement validés

Interdictions recommandées :

- accès direct des postes commerciaux à MySQL ;
- accès SMB/RDP/SSH généralisé vers les serveurs ;
- accès libre entre serveurs internes eux-mêmes, sauf flux documentés.

Règle 3 — Isoler strictement le VLAN 99 Management

Le VLAN 99 est destiné au management des équipements. Il doit être considéré comme une zone ultra-sensible.

Règles à définir :

- seuls les postes d'administration autorisés peuvent accéder au VLAN 99 ;
- interdiction totale depuis le Wi-Fi et le VLAN Commercial ;
- interdiction depuis Internet ;
- accès limité aux protocoles d'administration sécurisés : SSH, HTTPS, SNMPv3 ;
- interdiction de Telnet, HTTP non chiffré, SNMPv1/v2c.

Règle 4 — N'autoriser depuis Internet que les services publiés

La DMZ est prévue pour exposer les services Web et VPN. Le réseau interne ne doit jamais être directement exposé à Internet. Le schéma montre bien cette séparation logique entre Internet, pare-feu, DMZ et réseau interne.

Depuis Internet vers la DMZ :

- autoriser uniquement :
 - HTTPS vers le serveur Web ;
 - ports VPN nécessaires vers le serveur VPN ;
- refuser tout le reste.

Depuis Internet vers le LAN interne :

- interdiction totale.

Règle 5 — Limiter fortement les flux DMZ → réseau interne

Un serveur DMZ compromis est un grand classique. Il faut donc empêcher qu'il serve de tremplin vers l'interne.

Règles recommandées :

- DMZ → VLAN 40 : refus par défaut ;
- seules quelques exceptions documentées peuvent exister, par exemple :
 - serveur Web → base de données, sur port précis, vers IP précise ;
 - serveur VPN → annuaire d'authentification, si indispensable ;
- toute ouverture doit être nominative, justifiée et journalisée.

Règle 6 — Filtrer les sorties Internet des serveurs

Tous les serveurs n'ont pas besoin d'un accès Internet complet.

Exemples :

- AD/DNS : sorties très limitées ;
- MySQL : pas de navigation Internet ;
- SIEM : sorties limitées aux mises à jour ou flux de synchronisation nécessaires ;
- serveurs DMZ : sorties réduites au strict besoin.

Cela réduit les risques de téléchargement malveillant, d'exfiltration ou de commande à distance.

4.3 Règles Wi-Fi

La configuration montre un SSID unique **TechSecure-WiFi**, rattaché au **VLAN 30**, avec un mot de passe partagé.

Règle 7 — Considérer le Wi-Fi comme un réseau moins fiable

Même s'il est interne, le Wi-Fi doit être traité avec prudence.

Mesures à traduire en règles :

- le Wi-Fi ne doit pas avoir d'accès libre au VLAN 40 ;
- le Wi-Fi ne doit pas accéder au VLAN 99 ;
- le Wi-Fi doit être séparé des usages d'administration ;
- les flux Wi-Fi vers les serveurs doivent être réduits aux seules applications nécessaires.

Règle 8 — Séparer le Wi-Fi interne et le Wi-Fi invité

Dans une PME, mélanger collaborateurs et visiteurs sur le même SSID revient à laisser tout le monde entrer par la même porte avec le même badge.

Règle recommandée :

- créer un **SSID interne** pour les employés ;
- créer un **SSID invité** isolé, avec accès Internet uniquement ;
- aucun accès invité aux VLAN internes.

Règle 9 — Renforcer l'authentification Wi-Fi

Le mot de passe partagé convient mal à une logique de traçabilité. La règle cible doit être :

- passage à **WPA2-Enterprise** ou **WPA3-Enterprise** avec authentification individuelle ;
- révocation rapide des accès lors du départ d'un salarié ;
- interdiction du partage d'un secret commun entre tous les utilisateurs.

4.4 Règles d'administration

Règle 10 — Centraliser et restreindre les accès d'administration

L'administration des équipements réseau, du pare-feu, des serveurs et des bases doit suivre une politique dédiée.

Règles recommandées :

- accès d'administration uniquement depuis VLAN 10 ou un bastion ;
- comptes nominatifs obligatoires ;
- authentification multifacteur pour VPN, pare-feu, serveurs critiques ;
- interdiction d'utiliser les comptes administrateurs pour la bureautique quotidienne ;
- journalisation de toute action d'administration.

Règle 11 — Interdire les protocoles d'administration non sécurisés

À bannir :

- Telnet
- FTP
- HTTP d'administration
- SNMP non sécurisé

À autoriser :

- SSH
- HTTPS
- SFTP/SCP
- SNMPv3
-

4.5 Règles spécifiques à la base de données MySQL

La configuration fournie montre un utilisateur `dev_user` autorisé depuis `10.0.20.%` avec **ALL PRIVILEGES ON . WITH GRANT OPTION**, ce qui est beaucoup trop permissif.

Règle 12 — Restreindre les droits réseau et applicatifs vers MySQL

Règles à poser :

- seuls les hôtes applicatifs ou postes de développement explicitement identifiés peuvent joindre MySQL ;
- interdiction des connexions depuis tout le VLAN 30 ;
- interdiction des connexions administratives distantes ouvertes à large périmètre ;
- filtrage par IP source précise, pas seulement par sous-réseau large.

Règle 13 — Appliquer le moindre privilège sur les comptes BD

À corriger :

- supprimer `GRANT ALL PRIVILEGES ON *.*;`
- supprimer `WITH GRANT OPTION` pour un compte développeur ;
- créer des comptes séparés :
 - lecture seule ;
 - lecture/écriture applicative ;
 - administration BD restreinte ;
- journaliser les accès sensibles.

4.6 Règles sur les postes utilisateurs

Règle 14 — Bloquer les flux latéraux poste à poste

Dans les VLAN utilisateurs, les postes ne doivent pas se parler librement sauf besoin précis.

À limiter ou interdire :

- SMB entre postes ;

- RDP entre postes ;
- outils de prise en main à distance non autorisés ;
- scans réseau internes.

Cette règle casse une grande partie des scénarios de propagation de ransomware.

Règle 15 — Contrôler les sorties vers Internet

Tous les postes n'ont pas besoin des mêmes accès.

Exemples :

- VLAN Commercial : navigation Web, messagerie, CRM ;
- VLAN Développement : dépôts, documentation technique, outils CI/CD ;
- VLAN Administration : accès métier + administration ciblée ;
- blocage ou contrôle renforcé sur catégories à risque, téléchargements exécutables, services anonymisants.

5. Jeu de règles synthétique recommandé

Voici une version simple à intégrer dans la documentation :

Source	Destination	Règle	Justification
Internet	DMZ	Autoriser seulement HTTPS + VPN	exposition minimale
Internet	VLAN internes	Interdire	aucune exposition directe
DMZ	VLAN 40	Refuser par défaut	éviter pivot depuis DMZ
VLAN 30	VLAN 40	Interdire sauf application validée	protéger les serveurs
VLAN 30 / Wi-Fi	VLAN 99	Interdire	protéger l'administration
VLAN 20	MySQL 10.0.40.15	Autoriser seulement si besoin, sur port précis	accès contrôlé

VLAN 10	VLAN 99	Autoriser administration sécurisée	gestion des équipements
Tous VLAN utilisateurs	Tous autres VLAN utilisateurs	Refuser par défaut	limiter propagation latérale
Serveurs internes	Internet	Autoriser au strict nécessaire	réduire exfiltration
Wi-Fi invité	Réseau interne	Interdire	cloisonnement fort

6. Règles organisationnelles associées

Les règles techniques doivent être complétées par des règles de gouvernance :

6.1 Règle de validation

Toute nouvelle ouverture de flux doit être :

- demandée ;
- justifiée ;
- validée ;
- documentée ;
- revue périodiquement.

6.2 Règle de revue

Les ACL, règles pare-feu, droits d'accès et exceptions doivent être revus au moins tous les 6 mois.

6.3 Règle de traçabilité

Toute modification réseau ou sécurité doit laisser une trace :

- qui a demandé ;
- qui a validé ;
- quand ;
- pourquoi ;
- durée de validité si exception temporaire.

6.4 Règle de suppression

Tout accès temporaire doit expirer automatiquement ou être supprimé en fin de besoin.

7. Conclusion

L'infrastructure TechSecure est déjà structurée autour de VLAN, d'une DMZ et d'équipements de sécurité, ce qui constitue une bonne base. En revanche, pour que cette architecture soit réellement défensive, elle doit être complétée par des règles explicites de filtrage, d'administration et de cloisonnement. Les règles prioritaires sont :

1. **refus par défaut entre VLAN ;**
2. **protection renforcée du VLAN 40 et du VLAN 99 ;**
3. **contrôle strict des flux DMZ ↔ interne ;**
4. **isolement du Wi-Fi ;**
5. **restriction forte des accès à MySQL ;**
6. **journalisation des accès sensibles.**

Autrement dit : le réseau est bien découpé, mais sans règles strictes, il reste "rangé" sans être vraiment "verrouillé". Et en cybersécurité, un réseau simplement bien rangé fait surtout gagner du temps à l'attaquant.

Étape 10 — Identification des points de surveillance et des alertes à implémenter

Dans l'infrastructure TechSecure, plusieurs éléments doivent être placés sous surveillance continue : le routeur R1, le pare-feu ASA, le switch cœur S1, les VLAN métiers, la DMZ, les points d'accès Wi-Fi, le serveur AD/DNS, le SIEM et la base MySQL. Le schéma montre en particulier une architecture segmentée entre VLAN internes, DMZ et serveurs critiques, avec un SIEM déjà présent en VLAN 40, ce qui en fait le point central naturel pour la collecte et la corrélation des journaux.

1. Objectif de la supervision

L'objectif n'est pas de tout journaliser sans distinction. Il faut surveiller ce qui permet de détecter rapidement :

- une intrusion,
- un mouvement latéral entre VLAN,
- un abus de privilèges,
- une panne sur un équipement critique,
- une attaque sur les services exposés,
- une fuite ou une altération de données.

Autrement dit, la supervision doit servir à voir tôt ce qui coûterait cher plus tard.

2. Points de surveillance à mettre en place

2.1 Routeur R1

Le routeur assure la liaison WAN/LAN et la traduction d'adresses NAT. Il doit donc être surveillé pour détecter les anomalies de connectivité ou les usages suspects. L'annexe montre qu'il réalise le NAT sortant et qu'il route la DMZ via le pare-feu.

À surveiller :

- redémarrages du routeur,
- changements de configuration,
- perte de connectivité WAN,
- pics anormaux de trafic sortant,
- erreurs d'interface réseau,
- saturation CPU ou mémoire.

Alertes à implémenter :

- alerte si interface WAN ou LAN passe en down,
- alerte si modification de configuration non planifiée,

- alerte si volume de trafic sortant dépasse un seuil inhabituel,
- alerte si CPU ou mémoire reste élevé pendant plusieurs minutes.

2.2 Pare-feu ASA 5506-X

Le pare-feu est le point de contrôle majeur entre Internet, le réseau interne et la DMZ. L'annexe indique trois zones logiques : **outside**, **inside** et **dmz**, avec des niveaux de sécurité différents.

À surveiller :

- connexions refusées et autorisées,
- tentatives répétées d'accès à la DMZ,
- scans de ports,
- changements de règles,
- montée brutale du nombre de sessions,
- coupures entre inside et dmz.

Alertes à implémenter :

- alerte sur taux élevé de connexions refusées depuis Internet,
- alerte sur scan de ports détecté contre les serveurs DMZ,
- alerte sur ajout, suppression ou modification d'une règle firewall,
- alerte si un flux non prévu apparaît entre VLAN internes et DMZ,
- alerte si le pare-feu devient indisponible.

2.3 Switch cœur S1 et segmentation VLAN

Le switch L3 supporte les VLAN 10, 20, 30, 40 et 99. Il est central pour la segmentation réseau et le trafic inter-VLAN.

À surveiller :

- changements de configuration VLAN,
- apparition d'interconnexions non prévues,
- ports activés anormalement,
- boucles réseau,
- adresses MAC suspectes,
- trafic inter-VLAN inhabituel.

Alertes à implémenter :

- alerte sur création ou modification de VLAN,
- alerte sur activation d'un port de management non autorisé,
- alerte si un poste du VLAN 30 ou 20 tente d'accéder à des ressources sensibles du VLAN 99,
- alerte en cas de tempête broadcast ou d'augmentation forte du trafic inter-VLAN.

2.4 DMZ : serveurs exposés (Web et VPN)

Le schéma montre un serveur Web et un serveur VPN dans la DMZ. Ce sont des cibles de premier choix pour un attaquant externe.

À surveiller :

- disponibilité des services Web et VPN,
- erreurs HTTP répétées,
- authentications VPN échouées,
- hausse soudaine du trafic entrant,
- connexions depuis des pays ou IP inhabituels,
- exécution de processus anormaux sur les hôtes DMZ.

Alertes à implémenter :

- alerte si le service Web ou VPN devient indisponible,
- alerte si le nombre d'échecs d'authentification VPN dépasse un seuil,
- alerte en cas de trafic compatible avec un début de DDoS,
- alerte si un serveur DMZ initie soudainement des connexions vers l'interne non prévues.

2.4 Active Directory / DNS

Le serveur AD/DNS est un actif critique : il concentre l'authentification et la résolution de noms. Sa compromission aurait un effet systémique sur l'entreprise. Le schéma le place en VLAN 40 avec les serveurs internes.

À surveiller :

- échecs et réussites d'authentification,
- verrouillages de comptes,
- création de comptes administrateurs,
- modifications de groupes sensibles,
- activités anormales sur le DNS,
- arrêts de service.

Alertes à implémenter :

- alerte sur multiples échecs de connexion sur un même compte,
- alerte sur ajout d'un utilisateur dans un groupe administrateur,
- alerte sur création de compte à privilèges,
- alerte sur requêtes DNS anormales ou volumétrie inhabituelle,

- alerte si le service AD ou DNS devient indisponible.

2.5 Base MySQL / MariaDB

La base de données est particulièrement sensible, car elle contient potentiellement les données clients. L'annexe montre aussi un point très risqué : l'utilisateur `dev_user` depuis le VLAN 20 possède `ALL PRIVILEGES` avec `GRANT OPTION`, ce qui justifie une surveillance renforcée.

À surveiller :

- connexions à la base,
- requêtes d'administration,
- création d'utilisateurs,
- élévations de privilèges,
- exports massifs de données,
- erreurs répétées de connexion.

Alertes à implémenter :

- alerte sur connexion administrative hors horaires habituels,
- alerte sur création ou modification de privilèges base,
- alerte sur extraction volumineuse de données,
- alerte sur tentatives répétées d'accès échouées,
- alerte sur requêtes provenant d'une source inattendue.

2.6 Points d'accès Wi-Fi

Les AP diffusent le SSID `TechSecure-WiFi` sur le VLAN 30, qui correspond au réseau commercial. Toute compromission Wi-Fi peut offrir un point d'entrée discret.

À surveiller :

- connexions et déconnexions des clients,
- nombre d'équipements connectés,
- apparition d'adresses MAC inconnues,
- modifications du SSID ou du chiffrement,
- indisponibilité d'un AP.

Alertes à implémenter :

- alerte si un AP change de configuration,
- alerte si un nombre anormal d'équipements se connecte en peu de temps,
- alerte sur présence d'un équipement inconnu ou non autorisé,
- alerte si un AP devient indisponible.

2.7 SIEM

Le SIEM existe déjà dans l'architecture. Il doit agréger les journaux du routeur, du pare-feu, des serveurs, du switch et des équipements d'accès.

À surveiller :

- réception correcte des logs,
- rupture d'alimentation en journaux,
- corrélations multi-événements,
- santé de la plateforme SIEM.

Alertes à implémenter :

- alerte si une source critique n'envoie plus de logs,
- alerte si l'espace disque du SIEM est faible,
- alerte si la corrélation détecte une chaîne d'attaque,
- alerte si l'horodatage des logs devient incohérent.

3. Cas d'usage de détection prioritaires

Voici les scénarios d'alerte les plus utiles à implémenter en priorité :

1. Tentative d'intrusion externe

Déclencheurs :

- scans de ports sur la DMZ,
- pics de connexions refusées,
- erreurs répétées sur le serveur Web ou VPN.

But :

Détecter tôt une reconnaissance ou une attaque en préparation.

2. Compromission d'un poste utilisateur

Déclencheurs :

- trafic inhabituel depuis un poste d'un VLAN utilisateur,
- connexions vers plusieurs sous-réseaux en peu de temps,
- tentatives d'accès à des serveurs sensibles.

But :

Détecter un malware ou un mouvement latéral.

3. Abus de privilèges internes

Déclencheurs :

- élévation de droits sur AD,
- modification de comptes sensibles,
- création d'utilisateurs ou de privilèges dans MySQL.

But :

Détecter un compte compromis ou un usage malveillant interne.

4. Exfiltration de données

Déclencheurs :

- volume sortant inhabituel,
- export massif de base de données,
- connexions longues ou répétées vers une destination externe inhabituelle.

But :

Détecter une fuite d'informations clients ou de code source.

5. Dénî de service

Déclencheurs :

- saturation du serveur Web ou VPN,
- nombre anormal de sessions réseau,
- indisponibilité subite d'un service exposé.

But :

Détecter un DDoS ou une saturation volontaire.

4. Journaux à centraliser dans le SIEM

Pour que la supervision soit efficace, TechSecure doit centraliser au minimum :

- logs du pare-feu ASA,
- logs du routeur R1,
- logs du switch cœur S1,
- logs système des serveurs Web, VPN, AD/DNS, SIEM et MySQL,
- logs d'authentification Windows/Linux,

- logs DNS,
- logs Wi-Fi,
- logs de sauvegarde,
- logs d'administration et de changements de configuration.

Sans centralisation, on voit des signaux faibles. Avec centralisation, on voit l'attaque.

5. Priorisation des alertes

Pour éviter une "usine à faux positifs", les alertes doivent être classées par criticité.

Alertes critiques

- indisponibilité du pare-feu,
- indisponibilité AD/DNS,
- création de compte administrateur,
- extraction massive de données,
- absence de logs d'un équipement critique,
- tentative d'accès non autorisé à la DMZ ou au VLAN 99.

Alertes majeures

- nombreux échecs d'authentification,
- scan de ports,
- modification de configuration réseau,
- augmentation brutale du trafic inter-VLAN,
- activité inhabituelle sur la base MySQL.

Alertes mineures

- redémarrage d'un AP,
- hausse ponctuelle du CPU,
- erreur isolée de service,
- coupure momentanée d'un port non critique.

6. Recommandations opérationnelles

Pour rendre cette supervision exploitable, il est recommandé de :

- définir des seuils réalistes pour chaque alerte,
- synchroniser tous les équipements avec une même source NTP,

- conserver les journaux selon une durée définie,
- documenter les procédures de traitement des alertes,
- tester régulièrement les scénarios de détection,
- distinguer les alertes de sécurité des alertes purement techniques.

7. Conclusion

Dans l'infrastructure TechSecure, les points de surveillance prioritaires sont le routeur, le pare-feu, le switch cœur, les serveurs de la DMZ, l'Active Directory/DNS, la base MySQL, les points d'accès Wi-Fi et le SIEM. La supervision doit permettre de détecter rapidement les intrusions, les pannes, les abus de privilèges, les mouvements latéraux et les exfiltrations de données. Les alertes les plus importantes concernent les changements de configuration, les échecs d'authentification, les accès non autorisés, les volumes de trafic anormaux, l'indisponibilité des services critiques et les activités suspectes sur la base de données. Cette approche permet à TechSecure de transformer ses journaux techniques en capacité réelle de détection et de réponse aux incidents.

Étape 11 — Analyse des configurations (contrôles manquants ou mal configurés)

Objectif Identifier précisément les failles de configuration dans l'infrastructure de *TechSecure* afin de détecter :

- les contrôles absents
- les contrôles mal implémentés
- les mauvaises pratiques exploitables

Cette étape s'appuie directement sur les configurations fournies .

1. Analyse du pare-feu (FW1 - ASA 5506-X)

Problèmes identifiés:

1.1 Absence de règles ACL explicites

- Aucune règle de filtrage (ACL) n'est définie
- Le firewall repose uniquement sur les **security-levels**

Problème :

- Le trafic **inside** → **outside** est autorisé par défaut
- Risque de communication non contrôlée vers Internet

1.2 Segmentation DMZ insuffisante

- DMZ configurée avec un niveau 50
- Aucun filtrage spécifique entre :
 - DMZ ↔ LAN interne
 - DMZ ↔ Serveurs critiques

Risque :

- Un serveur compromis en DMZ peut pivoter vers le réseau interne

1.3 Pas de filtrage sortant

- Aucun contrôle des flux sortants (egress filtering)

Risque :

- Exfiltration de données clients
 - Communication avec serveurs malveillants (C2)
-

Recommandations

- Implémenter des ACL strictes :
 - Autoriser uniquement les ports nécessaires (HTTP, HTTPS, VPN)
- Bloquer par défaut tout trafic non autorisé
- Isoler strictement la DMZ

2. Analyse du routeur (R1)

Problèmes identifiés :

2.1 NAT trop permissif

```
access-list 1 permit 10.0.0.0 0.0.255.255
```

Problème :

- Autorise tout le réseau interne à sortir sans restriction

Risque :

- Difficulté de traçabilité
- Exposition large en cas de compromission interne

2.2 Absence de filtrage WAN

- Aucune ACL appliquée sur l'interface WAN

Risque :

- Attaques directes depuis Internet (scan, brute force)

Recommandations

- Restreindre le NAT aux flux nécessaires
- Ajouter ACL en entrée WAN :
 - Bloquer tout sauf trafic attendu (VPN, HTTPS)

3. Analyse de la segmentation réseau (VLAN)

Problèmes identifiés :

3.1 Absence de règles inter-VLAN

- VLANs bien définis :
 - Admin, Dev, Commercial, Serveurs, Management
- MAIS aucun contrôle des communications

Risque :

- Mouvement latéral facilité
- Un poste compromis peut accéder à tout le SI

3.2 VLAN Management exposé

- VLAN 99 (Management) présent
- Aucun contrôle d'accès spécifique

Risque :

- Accès aux équipements réseau (switch, firewall)

Recommandations

- Mettre en place des ACL inter-VLAN :
 - Dev → Serveurs : autorisé partiellement
 - Commercial → Serveurs : interdit
- Restreindre VLAN Management uniquement aux admins

4. Analyse du Wi-Fi (AP1 / AP2)

Problèmes identifiés

4.1 Mot de passe faible et partagé

wpa-psk ascii TechSecure@2025!

Problème :

- Clé unique pour tous les utilisateurs

Risque :

- Accès non contrôlé
- Difficulté de révocation d'un utilisateur

4.2 Pas de segmentation Wi-Fi

- Wi-Fi connecté directement au VLAN 30 (Commercial)

Risque :

- Un attaquant Wi-Fi accède au réseau interne

Recommandations

- Utiliser WPA2/WPA3 Enterprise (authentification individuelle)
- Créer un VLAN Wi-Fi invité isolé

5. Analyse du serveur MySQL

Problèmes identifiés :

5.1 Privilèges excessifs

GRANT ALL PRIVILEGES ON *.* TO 'dev_user'

Problème :

- Accès total à toutes les bases

Risque :

- Compromission totale des données clients

5.2 Accès réseau trop large

'dev_user'@'10.0.20.%'

Problème :

- Tous les postes Dev peuvent accéder à la DB

Risque :

- Propagation rapide d'une attaque

Recommandations

- Principe du moindre privilège :
 - Accès limité à une base spécifique
- Restreindre IP autorisées (whitelist)

6. Analyse des contrôles manquants globaux

Contrôles absents critiques

Journalisation centralisée insuffisante

- SIEM présent mais non exploité

Risque :

- Détection tardive des incidents

Absence d'IDS/IPS

- Aucun système de détection d'intrusion

Risque :

- Attaques invisibles

Pas de MFA (Multi-Factor Authentication)

- Accès sensibles non protégés

Risque :

- Compromission via phishing

Pas de durcissement des équipements

- Configurations par défaut visibles

Risque :

- Exploitation facile

7. Synthèse des faiblesses critiques

Domaine	Problème	Niveau de risque
Firewall	Pas d'ACL	● Élevé
VLAN	Mauvaise segmentation	● Élevé
Wi-Fi	Accès non sécurisé	● Élevé
Base de données	Privilèges excessifs	● Élevé
Routeur	Pas de filtrage WAN	● Élevé
Monitoring	SIEM sous-utilisé	● Moyen

8. Lecture pédagogique (important pour soutenance)

Ce qu'il faut retenir :

- La **majorité des risques ne viennent pas d'un manque d'équipement**, mais d'une **mauvaise configuration**
- L'infrastructure est **fonctionnelle mais peu sécurisée**
- Le principal problème est :

! l'absence de contrôle des flux (réseau, utilisateurs, applications)

Conclusion

L'infrastructure de *TechSecure* présente :

- une bonne base (VLAN, firewall, SIEM)
- mais des **configurations trop permissives**

Ce qui en fait une cible idéale pour :

- **attaques internes**
- **mouvements latéraux**
- **exfiltration de données**

La prochaine étape consistera à prioriser ces failles dans un plan d'action concret (remédiation avancée / gouvernance sécurité)

Étape 12 — Renforcement de la gouvernance sécurité et amélioration continue

Objectif: après avoir identifié les failles techniques, cette étape vise à structurer la sécurité dans la durée.

On passe d'une logique "correction ponctuelle" à une logique pilotée, mesurée et continue.

1. Mise en place d'une gouvernance sécurité

Problème actuel

- Sécurité principalement technique
- Pas de cadre global ni de pilotage

Risque :

- Actions isolées, non suivies
- Failles récurrentes dans le temps

Actions recommandées

1.1 Définir une politique de sécurité (PSSI)

Contenu :

- Règles d'accès aux systèmes
- Gestion des mots de passe
- Utilisation des ressources IT
- Gestion des incidents

Objectif :

- Donner un cadre clair à tous les employés

1.2 Désigner un responsable sécurité (RSSI ou référent)

Même dans une PME :

- rôle clé pour coordonner
- suivi des risques et incidents

2. Mise en place d'indicateurs de sécurité (KPI)

Pourquoi ?

Mesurer la sécurité permet de :

- suivre les améliorations
- détecter les dérives
- prioriser les actions

Exemples de KPI pertinents

Indicateur	Objectif
Nombre d'incidents détectés	Mesurer l'exposition
Temps de réponse incident	Évaluer la réactivité

% des systèmes à jour

Suivi des patches

Nombre de tentatives bloquées

Efficacité du firewall

Taux d'accès non autorisés

Contrôle des accès

3. Mise en place d'un processus de gestion des vulnérabilités

Problème actuel

- Failles identifiées mais pas de suivi structuré

Processus recommandé

Cycle continu :

1. Scan de vulnérabilités
2. Analyse des résultats
3. Priorisation (critique → faible)
4. Correction
5. Vérification

Outils possibles

- Scanner vulnérabilités (ex : OpenVAS)
- SIEM déjà présent (à exploiter)

4. Sensibilisation des utilisateurs

Problème

- L'humain reste la première faille (phishing, mots de passe)

Actions

4.1 Formation régulière

- Reconnaître un phishing
- Bonnes pratiques mots de passe
- Gestion des données sensibles

4.2 Simulations d'attaque

- Campagnes de phishing simulées

Objectif :

- Tester et améliorer le comportement réel

5. Gestion des accès et des identités (IAM)

Problème actuel

- Accès trop larges (ex : MySQL, VLAN)

Bonnes pratiques

- Principe du **moindre privilège**
- Mise en place du **MFA**
- Revue régulière des accès
- Désactivation des comptes inutilisés

6. Gestion des mises à jour (Patch Management)

Risque actuel

- Exploitation de vulnérabilités connues

Mise en place

- Politique de mise à jour régulière :
 - OS
 - équipements réseau
 - applications
- Priorisation :
 - critiques → immédiat
 - autres → planifiées

7. Mise en place d'un plan de réponse aux incidents (PRI)

Réagir rapidement en cas d'attaque

Contenu du plan

Étapes clés :

1. Détection (via SIEM)
2. Analyse
3. Confinement
4. Éradication
5. Restauration
6. Retour d'expérience

Rôles à définir

- Responsable incident
- Équipe technique
- Communication interne/externe

8. Audit et amélioration continue

Principe La sécurité n'est jamais "terminée"

Actions

- Audits réguliers (interne ou externe)
- Tests d'intrusion (pentest)
- Revue annuelle des risques

9. Synthèse stratégique

Axe	Objectif
Gouvernance	Structurer la sécurité
KPI	Mesurer et piloter
Vulnérabilités	Corriger en continu
Utilisateurs	Réduire les erreurs humaines
Accès	Limiter les privilèges
Incidents	Réagir efficacement

Conclusion

Jusqu'ici nous avpns:

- identifié les risques
- corrigé les failles

Maintenant :

ON mets en place un **système de sécurité durable**

TechSecure doit évoluer vers une approche :

- **proactive** (anticiper les risques)
- **mesurée** (KPI, suivi)
- **organisée** (gouvernance claire)